



Module d'informatique et de mathématique
Département d'informatique et de mathématiques

8INF950 : Sujet spécial en cybersécurité

Cybersécurité défensive : Mapping automatique de base de
données d'incident et de détection

Date : 9 juillet 2026
8INF950 : Sujet spécial en cybersécurité - Été 2026
XXXXXXXXXXXXXXXXXXXXXXXXXXXXX

Table des matières

1	Introduction	2
1.1	Problématique et objectifs	2
1.2	Contexte — VERIS	2
1.3	Contexte — MITRE ATT&CK	3
1.4	Contexte — Le mapping expert	3
1.5	Contexte — Les 7 capability groups	4
1.6	Contexte — Versions et formats de données	4
2	Méthodologie	5
2.1	La méthode actuelle de mapping	5
2.2	État de l'art — Alarmes SIEM et modèle REACT	5
2.3	État de l'art — Ontologies et unification (UCO)	6
2.4	État de l'art — Approches IA pour l'alignement sémantique	6
2.5	Notre pipeline expérimental	6
2.5.1	Architecture du projet	6
2.5.2	Pipeline en trois étapes	6
2.5.3	Principe anti-fuite	6
2.6	Tableau comparatif des trois solutions	7
3	Solution	7
3.1	Solution RAG	7
3.1.1	Principe	7
3.1.2	Flux par capacité VERIS	7
3.1.3	Deux variantes expérimentées	7
3.1.4	Modules logiciels	8
3.1.5	Technologies et configuration	8
3.1.6	Format de sortie	8
3.2	Solution Fine-tune	8
3.3	Solution PROMPT	8
3.4	Synthèse des trois solutions	8
4	Résultats	8
4.1	Configuration expérimentale	8
4.2	Résultats — Solution RAG	8
4.3	Résultats — Solution Fine-tune	9
4.4	Résultats — Solution PROMPT	9
5	Discussion	9
6	Conclusion	9

Table des figures

1	Pipeline global du projet : données brutes, trois solutions IA et comparaison aux experts.	5
---	--	---

1 Introduction

1.1 Problématique et objectifs

Dans un centre d'opérations de sécurité (SOC), les analystes doivent constamment relier des incidents décrits dans un vocabulaire normalisé aux techniques adverses documentées dans des référentiels offensifs. Ce travail d'alignement sémantique permet d'enrichir la détection, contextualiser les alertes et améliorer la conscience situationnelle, mais il reste en grande partie **manuel**, coûteux et peu reproductible.

L'objectif de ce projet est de **reproduire automatiquement, à l'aide de l'intelligence artificielle, le mapping expert entre le vocabulaire VERIS et le framework MITRE ATT&CK**, puis de mesurer la qualité des mappings produits par rapport à la référence officielle publiée par le CTID (*Mappings Explorer*).

Nous avons choisi de mettre trois approches sont mises en concurrence : **RAG** (Retrieval-Augmented Generation), **FINE_TUNE** (fine-tuning supervisé) et **PROMPT** (ingénierie de prompts). Nos contributions principales sont :

- un pipeline reproductible (préparation des données, génération, comparaison) ;
- un format de sortie standardisé `veris_to_mitre` (7 fichiers JSON par version) ;
- des scripts de comparaison automatisée contre le mapping expert ;
- une implémentation complète de la solution RAG, avec deux variantes expérimentées.

Le rapport s'organise comme suit : l'introduction présente le contexte technique (§1.2 à §1.6) ; la méthodologie décrit la pratique actuelle, l'état de l'art et notre cadre expérimental ; la section *Solution* détaille les trois approches retenues ; les résultats, la discussion et la conclusion clôturent l'analyse.

1.2 Contexte — VERIS

VERIS (*Vocabulary for Event Recording and Incident Sharing*) est un vocabulaire structuré conçu pour décrire de manière homogène les incidents de cybersécurité. Son objectif principal est de fournir un cadre commun pour documenter ce qui s'est produit lors d'un incident, indépendamment de l'organisation ou de l'outil utilisé. Autrement dit, VERIS sert à normaliser la description des événements de sécurité afin de faciliter leur analyse, leur comparaison et leur partage entre analystes, équipes de réponse à incident et organismes de recherche.

Sur le plan de son organisation, VERIS repose sur une structure hiérarchique. Le vocabulaire est découpé en grands axes, comme **action**, **attribute**, **actor** ou encore **value_chain**, qui correspondent à différentes dimensions d'un incident. Chaque axe contient ensuite des catégories plus précises, par exemple **hacking**, **malware** ou **social** dans l'axe **action**, puis des sous-catégories et des valeurs plus fines telles que **variety** ou **vector**. Cette organisation permet de représenter un incident avec plusieurs niveaux de granularité, depuis une vue générale jusqu'à une description beaucoup plus détaillée du comportement observé.

VERIS a été développé à l'origine dans le cadre des travaux de Verizon autour du *Data Breach Investigations Report* (DBIR), avec l'idée de disposer d'un schéma cohérent pour collecter et comparer les données d'incidents à grande échelle. Avec le temps, il est devenu un standard largement reconnu dans le domaine de la réponse à incident et de l'analyse cyber, notamment parce qu'il permet d'agréger des observations provenant de sources variées tout en conservant une structure commune. Dans le cadre de ce projet, VERIS

joue donc le rôle de référentiel décrivant le “quoi” de l’incident, que l’on cherche ensuite à relier au “comment” représenté par les techniques de MITRE ATT&CK.

1.3 Contexte — MITRE ATT&CK

MITRE ATT&CK (*Adversarial Tactics, Techniques, and Common Knowledge*) est une base de connaissances dédiée à la description des comportements adverses observés lors d'intrusions réelles. Contrairement à un simple catalogue de vulnérabilités ou d'outils, ATT&CK cherche à modéliser la manière dont un attaquant agit au cours d'une opération, c'est-à-dire les étapes, les objectifs intermédiaires et les techniques mobilisées. Dans cette perspective, ATT&CK décrit le “comment” d'une attaque, là où d'autres référentiels, comme VERIS, décrivent davantage le “quoi” de l'incident.

Le framework est organisé de manière hiérarchique autour de **tactiques** et de **techniques**. Les tactiques représentent les grands objectifs poursuivis par l'attaquant, par exemple l'accès initial, l'exécution, la persistance, l'élévation de privilèges ou l'impact. À l'intérieur de chaque tactique, ATT&CK recense des techniques identifiées par un code de type T1059, accompagnées d'un nom, d'une description et d'un ensemble de tactiques associées. Certaines techniques sont elles-mêmes décomposées en **sous-techniques**, notées par exemple T1059.001, ce qui permet de représenter plus finement des variantes de comportement ou des modes opératoires particuliers.

MITRE ATT&CK est maintenu par la MITRE Corporation à partir de retours d'expérience opérationnels, de rapports d'incidents et d'observations issues du renseignement sur les menaces. Il s'est progressivement imposé comme une référence majeure en cybersécurité défensive, notamment pour la détection, la chasse aux menaces, l'évaluation de couverture et la structuration des connaissances sur les attaques. Dans le cadre de ce projet, ATT&CK constitue le référentiel cible vers lequel les capacités VERIS sont mappées, afin de relier la description d'un incident aux techniques adverses susceptibles d'en expliquer le déroulement.

1.4 Contexte — Le mapping expert

Le mapping étudié dans ce projet consiste à relier des capacités issues du vocabulaire VERIS, qui décrivent la nature et les caractéristiques d'un incident, à des techniques du framework MITRE ATT&CK, qui décrivent les comportements et modes opératoires adverses susceptibles d'expliquer cet incident. Autrement dit, il s'agit de faire le lien entre le “quoi” observé dans VERIS et le “comment” modélisé dans ATT&CK. Concrètement, une capacité VERIS, par exemple `action.hacking.variety.SQLi`, peut être associée à une ou plusieurs techniques ATT&CK jugées pertinentes par les experts.

Ces correspondances sont produites et publiées par le CTID / MITRE Engenuity dans l'outil *Mappings Explorer* [1]. Elles constituent dans notre travail une double référence : d'une part, elles définissent la cible que nos solutions d'intelligence artificielle cherchent à reproduire automatiquement ; d'autre part, elles servent de base d'évaluation pour mesurer la qualité des mappings générés. Le problème traité dans ce projet n'est donc pas seulement de produire des associations plausibles entre VERIS et ATT&CK, mais bien de se rapprocher le plus possible d'un mapping expert déjà établi.

Toutefois, ce travail de correspondance ne porte pas sur l'ensemble du schéma VERIS, mais uniquement sur sept groupes dits “comportementaux”, considérés comme les plus pertinents pour un rapprochement avec ATT&CK. Ces capability groups couvrent princi-

palement les actions menées lors d'un incident ainsi que certains impacts observables sur l'intégrité, la confidentialité, la disponibilité ou la chaîne de développement. Le Tableau reftab :capability-groups présente les volumes de référence associés à ces sept groupes pour la paire VERIS 1.4.1 / ATT&CK 19.1.

1.5 Contexte — Les 7 capability groups

Seuls sept groupes VERIS dits « comportementaux » sont mappés vers ATT&CK. Le Tableau 1 présente les volumes pour la paire de référence VERIS 1.4.1 / ATT&CK 19.1.

Capability group	Paires VERIS↔ATT&CK	Capacités VERIS
action.hacking	538	68
action.malware	405	54
action.social	78	23
attribute.integrity	91	13
attribute.confidentiality	73	1
attribute.availability	44	6
value_chain.development	25	12

TABLEAU 1 – Les sept capability groups VERIS mappés (référence 1.4.1 / 19.1).

Cas particulier : pour `attribute.confidentiality`, les experts mappent le champ `data_disclosure` lui-même (une seule capacité), et non des valeurs sous `variety`.

1.6 Contexte — Versions et formats de données

Quatre paires de versions sont supportées de bout en bout : ATT&CK 9.0 / VERIS 1.3.5, 12.1 / 1.3.7, 16.1 / 1.4.0 et 19.1 / 1.4.1. La **version cible d'évaluation** de ce rapport est VERIS 1.4.1 / ATT&CK 19.1 (clé `veris-1.4.1_attack-19.1-enterprise`).

Les entrées préparées pour chaque solution sont :

- `veris_<v>.json` : capacités VERIS dans les sept groupes (les « questions ») ;
- `attack_<a>.json` : techniques ATT&CK non dépréciées (les « candidats »).

Les sorties des solutions suivent le format `veris_to_mitre` ; la référence experte utilise le format CTID (`mapping_objects`).

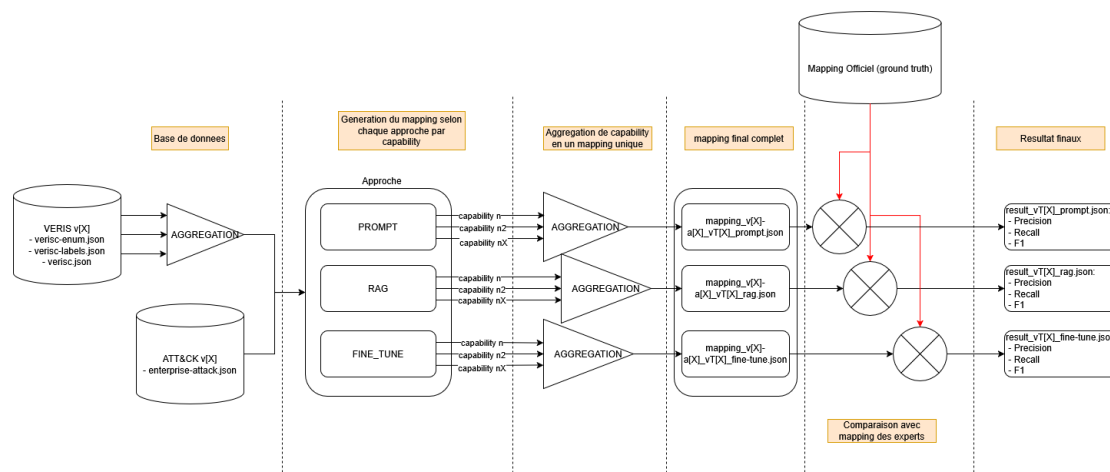


FIGURE 1 – Pipeline global du projet : données brutes, trois solutions IA et comparaison aux experts.

2 Méthodologie

2.1 La méthode actuelle de mapping

Aujourd'hui, le mapping VERIS $\rightarrow$ ATT&CK est réalisé par des experts du CTID / MITRE Engenuity [1]. Le processus est essentiellement **manuel** : pour chaque capacité VERIS, l'expert analyse sa sémantique, consulte le catalogue ATT&CK et sélectionne les techniques correspondantes (y compris les sous-techniques lorsque nécessaire). Les résultats sont publiés via l'outil *Mappings Explorer* au format CTID.

Cette approche présente des **avantages** indiscutables : haute qualité, validation par des spécialistes et référence largement adoptée. Ses **limites** sont toutefois significatives : coût en temps humain, faible scalabilité et nécessité de recommencer le travail à chaque nouvelle version de VERIS ou d'ATT&CK. Notre projet vise précisément à automatiser cette tâche tout en mesurant l'écart par rapport à cette référence experte.

2.2 État de l'art — Alarmes SIEM et modèle REACT

On distingue trois types de faux positifs (FP) dans les systèmes SIEM [3] :

- **Vraies alarmes** : menaces réelles.
- **Fausse alarmes** : déclenchement sans raison légitime.
- **Alarmes bénignes** : techniquement correctes, mais correspondant à un comportement légitime.

La validation des alarmes repose encore largement sur l'expertise humaine. Les auteurs proposent le modèle **REACT** : les alarmes doivent être **R**eliable (fiables), **E**xplained (explicables), **A**nalytical (analytiques), **C**ontextual (contextuelles) et **T**ransférables (transférables). Ce cadre guide la conception d'outils fondés sur l'apprentissage automatique. Dans notre projet, l'automatisation du mapping VERIS $\leftrightarrow$ ATT&CK vise à réduire la charge cognitive des analystes en normalisant plus rapidement le lien entre incidents et techniques adverses.

2.3 État de l'art — Ontologies et unification (UCO)

UCO (*Unified Cybersecurity Ontology*) [6] est une ontologie sémantique visant à unifier des données hétérogènes de cybersécurité (STIX, CVE, CAPEC, CybOX, *Kill Chain*, etc.) en OWL/RDF, ce qui autorise le raisonnement automatique. L'alignement VERIS ↔ ATT&CK s'inscrit dans cette problématique plus large d'**unification de taxonomies cyber** : deux vocabulaires distincts doivent être reliés de manière cohérente pour améliorer la conscience situationnelle des analystes.

2.4 État de l'art — Approches IA pour l'alignement sémantique

Trois familles d'approches sont comparées dans ce projet :

- **Prompt engineering** : un LLM généraliste produit le mapping à partir d'instructions (zero-shot ou few-shot). Mise en place rapide, mais risque élevé d'hallucination.
- **Fine-tuning** : un modèle est entraîné sur des paires expert annotées. Spécialisation forte et faible hallucination, mais coût d'entraînement plus élevé.
- **RAG** [5] : un contexte pertinent (techniques ATT&CK, exemples experts) est récupéré avant la décision. Compromis entre interprétabilité, coût et performance.

2.5 Notre pipeline expérimental

2.5.1 Architecture du projet

Le dépôt SIEM s'organise en quatre zones principales : **data/** (sources brutes VERIS, ATT&CK et mappings experts), **data_for_work/** (entrées préparées par version), **Solution/** (code des trois approches IA) et **Resultat/** (sorties et scripts de comparaison).

2.5.2 Pipeline en trois étapes

1. **Préparation** — `tools/build_work_inputs.py` transforme les données brutes en fichiers `veris_<v>.json` et `attack_<a>.json`.
2. **Génération** — chaque solution produit **sept fichiers JSON** (un par capability group) au format `veris_to_mitre`.
3. **Comparaison** — `Resultat/compare_veris_mappings_v2.py` confronte les sorties au mapping expert et calcule précision, rappel et F1.

2.5.3 Principe anti-fuite

Pour éviter toute fuite de données, le mapping expert de la version **cible** (1.4.1 / 19.1) n'est **jamais** utilisé comme exemple d'entraînement ou d'indexation. Seules les versions antérieures (9.0, 12.1, 16.1) servent d'exemples analogiques dans la variante RAG `with_examples`.

2.6 Tableau comparatif des trois solutions

Critère	RAG	FINE_TUNE	PROMPT
Données d'apprentissage	Index vectoriel + exemples	Paires expert (v. antérieures)	Few-shot o
Modèle	Embeddings + LLM (opt.)	Modèle fine-tuné	LLM géné
Retrieval	Oui (ChromaDB)	Non	Non
Risque d'hallucination	Modéré (validation catalogue)	Faible	Élevé
État dans le projet	Implémenté	Non implémenté	Non implé

TABLEAU 2 – Comparaison synthétique des trois solutions.

3 Solution

Les trois solutions partagent les mêmes entrées (`veris_<v>.json`, `attack_<a>.json`) et la même sortie attendue (sept fichiers `veris_to_mitre`), mais diffèrent par leur stratégie de décision IA.

3.1 Solution RAG

3.1.1 Principe

La solution **RAG** ancre chaque décision dans du contexte récupéré via deux corpus vectoriels ChromaDB :

1. `attack_techniques` — catalogue ATT&CK cible (les candidats) ;
2. `expert_examples` — mappings experts des versions antérieures (exemples analogiques).

Pour chaque capacité VERIS, le système récupère les techniques les plus similaires (top- k) et, le cas échéant, des exemples de mappings experts (top- m), puis produit une décision structurée en JSON.

3.1.2 Flux par capacité VERIS

Le traitement suit la chaîne suivante : (1) récupération des candidats ATT&CK ; (2) récupération des exemples experts (variante `with_examples`) ; (3) décision via le backend configuré (`retrieval`, `local_llm` ou `llm Azure`) ; (4) validation anti-hallucination (rejet des identifiants hors catalogue) ; (5) enrichissement des libellés et tactiques depuis le catalogue local ; (6) agrégation en entrées `veris_to_mitre` regroupées par capability group.

3.1.3 Deux variantes expérimentées

Mode	Corpus de récupération	Dossier de sortie
<code>attack_only</code>	ATT&CK seul	<code>..._RAG_attack_only/</code>
<code>with_examples</code>	ATT&CK + exemples experts	<code>..._RAG_with_examples/</code>

TABLEAU 3 – Variantes expérimentées de la solution RAG.

3.1.4 Modules logiciels

Fichier	Rôle
config.py	Versions, chemins, hyperparamètres
ingest.py	Indexation ChromaDB
retrieve.py	Récupération top- k / top- m
prompt.py	Prompts et schéma JSON
generator.py	Backends de génération
generate_mapping.py	Pipeline complet → 7 fichiers

TABLEAU 4 – Modules principaux de la solution RAG (`veris_mapping/`).

3.1.5 Technologies et configuration

En mode local (défaut), les embeddings sont produits par `sentence-transformers` et la génération peut s'appuyer sur la seule similarité cosinus (`retrieval`), sans LLM. En mode Azure (optionnel), les embeddings et la génération passent par Azure OpenAI. Les paramètres clés sont `RAG_TOP_K_TECHNIQUES` (20 par défaut) et `RAG_TOP_M_EXAMPLES` (5 par défaut).

3.1.6 Format de sortie

Chaque fichier de résultat contient une liste `veris_to_mitre` avec, pour chaque capacité, les techniques proposées, un score de confiance et une justification. Les identifiants ATT&CK invalides sont rejetés ; noms et tactiques proviennent du catalogue local.

3.2 Solution Fine-tune

3.3 Solution PROMPT

3.4 Synthèse des trois solutions

4 Résultats

4.1 Configuration expérimentale

4.2 Résultats — Solution RAG

Le Tableau 5 résume les performances globales des deux variantes RAG. L'injection d'exemples experts des versions antérieures **double le F1** (27,4 % contre 9,8 %), principalement grâce à un gain de rappel.

Variante	Précision	Rappel	F1
RAG_with_examples	18,9 %	49,7 %	27,4 %
RAG_attack_only	7,2 %	15,4 %	9,8 %

TABLEAU 5 – Résultats globaux RAG vs mapping expert (mode `retrieval` local).

Le mode `retrieval` privilégie le rappel au détriment de la précision : de nombreuses paires expertes sont retrouvées, mais beaucoup de propositions sont incorrectes. Certaines familles de sous-techniques (par exemple T1546.*) restent partiellement couvertes lorsque le top- k est insuffisant.

4.3 Résultats — Solution Fine-tune

4.4 Résultats — Solution PROMPT

5 Discussion

6 Conclusion

Références

- [1] CTID mappings explorer. <https://center-for-threat-informed-defense.github.io/mappings-explorer/>.
- [2] MITRE ATT&CK. <https://attack.mitre.org/>.
- [3] Towards reliable and explainable security alarm analytics. Modèle REACT pour la réduction des faux positifs SIEM.
- [4] VERIS community schema. <https://veriscommunity.net/>. Vocabulary for Event Recording and Incident Sharing.
- [5] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, Sebastian Riedel, and Douwe Kiela. Retrieval-augmented generation for knowledge-intensive NLP tasks. *Advances in Neural Information Processing Systems*, 33, 2020.
- [6] Zubair Syed, Tim Padia, Tim Finin, Michael Mathews, and Anupam Joshi. UCO : A unified cybersecurity ontology. In *Proceedings of the AAAI Workshop on Artificial Intelligence for Cyber Security*, 2015.